

TICKET #006

FINAL INVESTIGATION REPORT

The 9:17 A.M. Alert

Field	Value
Asset	FIN-WS17
Department	Finance
User	mreynolds
Initial Alert	09:17
Final Classification	Confirmed Security Incident
Environment	Controlled cybersecurity lab simulation

Confirmed unauthorized external transmission of Finance data through unapproved and unverified software, with malware status and ultimate root cause unresolved.

1. Executive Summary

At 09:17, Security received a high-severity alert for unusual outbound HTTPS activity from FIN-WS17, a Finance workstation associated with user mreynolds.

Initial evidence did not establish whether the activity was legitimate or malicious, so Security preserved evidence and investigated without immediately disrupting Finance operations.

The investigation later confirmed that Finance data was packaged and transmitted externally through document_cache.sh, a recently introduced, non-standard utility outside the documented approved Finance workflow.

At 11:00, recurring communications from the same process materially increased the assessed risk and justified network containment of FIN-WS17 while keeping the workstation powered on for evidence preservation.

At 11:40, Security learned that the employee had installed the utility after receiving an email represented as coming from a known Finance vendor. The employee believed the software was required to convert financial data.

Further technical analysis showed that neither the client utility nor the external server performed an observable data-conversion function. Instead, the utility archived Finance files, transmitted them externally, and deleted the temporary archive. The receiving server stored the uploaded data.

Final Classification

Confirmed Security Incident - unauthorized external transmission of Finance data through unapproved and unverified software, with malware status and ultimate root cause unresolved.

The investigation did not establish that the employee acted maliciously, that the software was definitively malware, or whether the vendor was impersonated, compromised, or legitimately associated with the software.

FIN-WS17 should remain isolated pending remediation and validation. Finance business continuity should continue through a clean trusted workstation, validated business files, and approved software.

2. Initial Alert

At 09:17, the SOC generated a high-severity alert for unusual outbound network activity.

Field	Value
Asset	FIN-WS17
User	mreynolds
Department	Finance

Destination	External IP
Protocol	HTTPS / TCP 443
First observed	09:12
Severity	High
Workstation status	Operational
User-reported issues	None
Confirmed compromise at alert time	No

The alert established unusual outbound activity but did not identify the initiating process, destination ownership, data transmitted, or whether the activity was malicious.

3. Environment

The investigation was conducted in a controlled lab simulating FIN-WS17.

Simulated Workstation

- Asset: FIN-WS17
- Lab host: ubuntu-soc-lab
- Operating system: Ubuntu Linux
- User: mreynolds
- Department: Finance
- Workstation lab IP: 192.168.56.121

Simulated External Service

- External test IP: 198.51.100.77
- Hostname: finance-sync.local
- Protocol: HTTPS / TCP 443
- Supporting server: Kali Linux
- Kali Host-Only IP: 192.168.56.111

Telemetry Sources

- auditd
- tcpdump packet capture
- External server logs
- File hashes
- Static script analysis
- Filesystem metadata

- TLS certificate inspection
- Preserved synthetic Finance data

The scenario used fictional business-day times for decision-making and communications. Raw technical evidence retained the actual lab-generation timestamps from September 6, 2026.

4. Known Facts at 09:17

Before deeper investigation, Security documented only the facts supplied by the initial alert:

- A high-severity alert had been generated.
- FIN-WS17 was the affected workstation.
- mreynolds was the associated Finance user.
- Unusual outbound HTTPS activity had been observed.
- The first observed activity was at 09:12.
- The destination was external.
- The workstation remained operational.
- Finance was actively working.
- No user had reported a problem.
- No compromise had been confirmed.

At this stage, Security did not yet know:

- Destination ownership.
- Destination reputation.
- The initiating process.
- Whether the activity was expected.
- What data, if any, had been transmitted.
- Whether the user initiated the activity.
- Whether persistence existed.
- Whether credentials or sensitive data were involved.

5. Initial Hypotheses

Hypothesis 1 - Legitimate Finance Application Activity

The outbound communication could have been produced by an approved Finance application or business service.

Hypothesis 2 - Legitimate Application Behaving Abnormally

An approved application could have been functioning incorrectly or communicating in an unusual but non-malicious manner.

Hypothesis 3 - Unauthorized Data Transfer

A user or process could have been transmitting Finance data to an unauthorized external destination.

Hypothesis 4 - Command-and-Control Communication

The connection could have represented communication between compromised software and attacker-controlled infrastructure.

Hypothesis 5 - Compromised User or Application Session

An attacker could have obtained access through the user account, application session, or another endpoint process.

No single hypothesis was treated as established at the initial stage.

6. Investigation Methodology

The investigation used a hypothesis-driven approach and progressively correlated host, process, file, network, and external-server evidence.

1. Preserve network and endpoint telemetry.
2. Identify outbound connection timing.
3. Correlate network activity with process execution.
4. Identify files accessed by the responsible processes.
5. Review external-server logs.
6. Recover and separate received POST bodies.
7. Compare externally received files with source files using SHA-256.
8. Review the questioned utility statically.
9. Check for cron and systemd persistence.
10. Review file metadata and creation timing.
11. Compare the questioned utility with the documented Finance workflow.
12. Reassess hypotheses as new information became available.
13. Validate the employee explanation against observable software behavior.
14. Inspect the external server for conversion logic.
15. Review TLS identity and certificate-validation behavior.
16. Separate confirmed facts from inference and unresolved questions throughout the investigation.

The investigation intentionally avoided treating antivirus non-detection, employee installation, unsigned status, or destination reputation as conclusive by themselves.

7. Evidence

Endpoint Evidence

- fin-ws17-final-audit.log
- fin-ws17-final-https.pcap
- scripts/document_cache.sh
- scripts/finance_sync.sh
- fin-ws17/system-profile.txt
- logs/soc-alert-0917.txt

External Server Evidence

- external-server/server.log
- external-server/received-data.bin
- external-server/cache-body.bin
- external-server/report-body.bin
- external-server/Q3_budget.csv
- external-server/vendor_payments.csv
- external-server/server.py
- external-server/server.crt

Key Technical Findings

- finance_sync.sh transmitted daily_summary.txt.
- document_cache.sh created an archive containing Q3_budget.csv and vendor_payments.csv.
- The archive was transmitted externally using HTTPS.
- The temporary archive was deleted after transmission.
- The external server logged POST /api/report (111 bytes) and POST /api/cache (390 bytes).
- Externally recovered Finance files matched the preserved source files by SHA-256.
- Static analysis identified no observable data-conversion logic.
- The external server contained no observable conversion logic and stored uploaded request bodies.
- The TLS certificate was self-signed for finance-sync.local.
- The questioned client used curl -k, disabling normal certificate validation.
- No associated cron or systemd persistence was identified.

Field	Value
Q3_budget.csv SHA-256	59e056b7075770c20cba2a4b265e764fb423f418153b8fd46a705850ae3545f9

vendor_payments.csv SHA-256	6dfc38b02c7da0c1bc5165a3b391495e03a993f21c63457904883ac95e64eb07
document_cache.sh SHA-256	1ee17971ce3cfb330457383ed019631b12ef9a8d738c560b1aad795329ee0c1c

8. Timeline

The full technical timeline is maintained separately as incident-timeline.csv. The summary below distinguishes event time from when Security learned the information.

Event Time	Investigator Learned	Event / Decision
Earlier morning	11:40	Employee receives and installs purported vendor utility.
09:12	09:17	Unusual outbound HTTPS activity first observed.
09:17	09:17	SOC alert generated.
09:30	09:30	Communication #1 issued.
10:05	10:05	Destination context changes; continued communication reported.
10:15	10:15	Decision Point #1 and Communication #2.
11:00	11:00	Recurring activity from same recently introduced non-standard process established; Decision Point #2 recommends full network containment.
11:10	11:10	Communication #3 issued to CISO.
11:40	11:40	Employee installation and vendor explanation become known; investigation pivots to provenance and behavior validation.
12:30	12:30	Finance reports two-hour deadline; Decision Point #3

		maintains containment and establishes clean-system continuity.
13:30	13:30	Final investigation and classification completed.

9. Decision Point #1

At 10:15, Security had confirmed external transmission of Finance data through document_cache.sh, but broader compromise had not yet been established.

- Destination infrastructure was also used by legitimate organizations.
- No antivirus alert had been generated.
- No cron or systemd persistence was identified.
- The workstation remained operational.
- The user reported no unusual behavior.

Decision

Use targeted containment and increased monitoring rather than immediately isolating FIN-WS17.

Rationale: reduce security risk while avoiding premature disruption of time-sensitive Finance work. The decision was explicitly subject to escalation if further unauthorized transfer, persistence, credential theft, lateral movement, command-and-control behavior, or other corroborating evidence appeared.

10. Decision Point #2

At 11:00, new evidence established regular recurring outbound communications, the same process responsible for each connection, a recently introduced non-standard file, an interactive user session, and continued uncertainty about software purpose. Endpoint tools still did not classify the file as malware.

Decision

Change the recommendation to full network containment of FIN-WS17 while keeping the workstation powered on.

The combination of previously confirmed Finance-data transmission and newly established recurring behavior materially increased the risk. The activity now appeared ongoing rather than isolated, and the security risk of continued connectivity exceeded the operational benefit of leaving the workstation online.

11. Investigation Pivot

At 11:40, Security learned that mreynolds had installed the software earlier that morning after receiving a link represented as coming from a known Finance vendor. The employee believed the software was required to convert financial data for that day's report.

This changed the investigation but did not establish legitimacy. Security pivoted to distinguish among:

- Legitimate vendor software.
- Legitimate but unauthorized software.
- Compromised vendor infrastructure.
- Phishing or impersonation.
- Trojanized software.
- Another undocumented explanation.

Pivot Findings

- The live and preserved copies of document_cache.sh matched by SHA-256.
- Static analysis showed the utility created a compressed archive, added two Finance files, sent the archive externally, and deleted the temporary archive.
- No observable conversion logic was identified.
- A filesystem search identified no apparent converted output file in the user's home directory during the relevant lab interval.
- The external server accepted uploaded data, stored it in received-data.bin, returned "Upload received," and performed no observable conversion.
- The TLS certificate was self-signed, and the client disabled certificate verification.

These findings materially weakened the stated conversion explanation but did not establish whether the vendor, infrastructure, email, or software was malicious.

12. Decision Point #3

At 12:30, Finance reported that Mark's converted files were needed within two hours or the reporting deadline could be missed. Security still had not established the ultimate root cause.

Workstation Decision

FIN-WS17 should remain network isolated and powered on. It should not be reconnected merely to meet the reporting deadline.

Business Continuity Decision

- Continue work using a clean trusted workstation.
- Recover required business data from known-good sources where possible.
- If files exist only on FIN-WS17, recover only specific required documents through a controlled Security/IT process.

- Validate recovered files before use.
- Use an approved corporate conversion application, a known-good IT-validated utility, a trusted manual workflow, or a vendor method only after independent validation.
- Contact the known vendor through previously established contact information, not through the questionable email or download site.

Business pressure influenced the continuity plan but did not justify restoring an unresolved high-risk workstation to the network. The response separated the legitimate business requirement from the affected endpoint.

13. Final Findings

- FIN-WS17 generated unusual outbound HTTPS activity.
- Finance data was packaged and transmitted externally.
- The questioned process was `document_cache.sh`.
- The utility was recently introduced and was not part of the standard operating system.
- The employee installed the utility earlier that morning.
- The employee believed the software came from a known Finance vendor and was needed for data conversion.
- IT did not deploy the utility.
- Security did not approve the utility.
- The utility was not digitally signed.
- Available endpoint security tooling did not classify the file as malware.
- The original vendor email and download location were not independently verified.
- `document_cache.sh` did not perform an observable data-conversion function.
- The receiving server did not perform an observable data-conversion function.
- The utility compressed Finance files and transmitted them externally.
- The receiving server stored the uploaded data.
- The externally recovered Finance files matched the source files by SHA-256.
- The external server used a self-signed certificate.
- The client disabled normal TLS certificate verification with `curl -k`.
- No associated cron or systemd persistence mechanism was identified.
- The investigation did not establish malicious intent by the employee.
- The investigation did not establish whether the software was definitively malware.
- The ultimate source and intent of the software remained unresolved.

14. Final Classification

Confirmed Security Incident

Confirmed unauthorized external transmission of Finance data through unapproved and unverified software, with malware status and ultimate root cause unresolved.

This classification is based on the confirmed security impact rather than on a malware verdict. Finance data left the workstation through a process outside the documented approved workflow, and the observed behavior of that process did not match the business purpose represented to the employee.

The investigation does not conclude that the employee intentionally caused the incident or that the known vendor was necessarily responsible.

15. Business Impact

The incident created direct operational pressure on Finance. Mark was preparing time-sensitive financial reports, and Finance stated that converted files were required within two hours to avoid missing the reporting deadline. Containment of FIN-WS17 therefore carried a meaningful operational cost.

- Provide a clean replacement workstation.
- Recover validated business data.
- Use an approved conversion method.
- Independently validate the vendor.

This approach reduced security exposure without unnecessarily stopping the broader Finance function.

16. Security Impact

The primary confirmed security impact was unauthorized external transmission of Finance data.

- Q3_budget.csv
- vendor_payments.csv

The investigation confirmed successful external receipt and byte-for-byte correspondence with the source files.

Potential additional concerns included continued recurring communications, recently introduced unapproved software, disabled TLS certificate validation, unverified software provenance, and possible phishing, impersonation, vendor compromise, or Trojanized software.

No evidence obtained during the investigation established lateral movement, credential theft, or broader host compromise.

17. Containment and Remediation

Containment

At Decision Point #2, Security determined that FIN-WS17 should be isolated from the network while remaining powered on to stop further external communication, reduce the risk of additional data transfer, preserve evidence, and allow controlled investigation.

Because FIN-WS17 was simulated within the shared lab host, the exercise documented the containment decision rather than physically disabling the lab network interface.

Immediate Remediation

- Prevent further execution of document_cache.sh.
- Preserve a verified copy of the questioned utility.
- Preserve network, audit, and server evidence.
- Validate the original vendor email independently.
- Validate the download source independently.
- Obtain a known-good vendor software copy and hash if available.
- Determine whether any additional Finance data was exposed.
- Review relevant credentials for possible compromise.
- Review the endpoint for additional persistence or unauthorized software.

Endpoint Remediation

- Remove unapproved software.
- Complete endpoint security review.
- Confirm no additional suspicious persistence or processes remain.
- Validate required Finance applications.
- Patch and update the workstation as appropriate.
- Reset credentials if exposure cannot be ruled out.
- Reconnect only after Security determines residual risk is acceptable.

18. Recovery

1. Provide Mark with a clean corporate workstation or approved virtual desktop.
2. Recover business files from known-good sources where possible.
3. If necessary, recover only validated business documents from FIN-WS17 through a controlled process.
4. Scan and verify recovered files.
5. Do not migrate questioned scripts or executables.
6. Use an approved Finance conversion tool or trusted manual workflow.
7. Independently validate the vendor before using vendor-provided software.
8. Return FIN-WS17 to production only after remediation and security approval.

19. Confidence Assessment

Confidence	Assessment
High	Finance data was transmitted externally;

	document_cache.sh performed the archive-and-transfer behavior; externally received Finance files matched the originals; the questioned utility and external server did not perform observable conversion; the software was outside the documented approved workflow; containment was justified once recurring behavior was established.
Medium-High	The questioned software should be treated as untrusted; the workstation required remediation before returning to service.
Low	Whether the vendor sent the original email; whether vendor infrastructure was compromised; whether the sender impersonated the vendor; whether the software was Trojanized; whether the software meets a formal malware classification; the ultimate identity and intent of the software supplier.

20. Residual Risk

Residual risk remains until several unresolved questions are addressed.

- Unknown software provenance.
- Unknown authenticity of the original vendor email.
- Unknown authenticity of the download site.
- Possible additional data exposure.
- Possible credential exposure.
- Possible additional unauthorized software or persistence not identified during the scoped investigation.
- Potential recurrence if Finance users continue installing unverified vendor utilities.

Residual risk should remain elevated until endpoint remediation, vendor validation, exposure review, and policy remediation are completed.

21. Recommendations

Technical Recommendations

- Maintain containment until endpoint remediation is complete.
- Preserve all final evidence and checksum manifests.
- Validate email headers and sender authenticity if available.
- Review browser and download history.
- Validate the original download URL and domain ownership.

- Obtain a known-good vendor copy and compare SHA-256.
- Perform additional endpoint and credential review.
- Review network, DNS, proxy, and authentication logs where available.
- Assess whether any additional Finance data was transmitted.

Process Recommendations

- Require IT or Security approval before installing vendor utilities.
- Provide Finance with an expedited software-validation process for time-sensitive vendor tools.
- Educate users to validate unexpected software requests through known vendor contact channels.
- Strengthen application allowlisting where practical.
- Improve monitoring for newly introduced processes making recurring external connections.
- Ensure Finance has documented approved conversion tools and backup workflows.
- Establish a clean-workstation continuity procedure for security incidents.

Communication Recommendations

- Continue separating confirmed facts, assessment, and uncertainty.
- State confidence explicitly.
- Explain what evidence would change the decision.
- Include business impact in containment recommendations.
- Preserve time-stamped communications without rewriting them after later evidence emerges.

22. Lessons Learned

Ticket #006 demonstrated that incident response requires disciplined judgment under uncertainty.

- An unusual destination does not prove maliciousness.
- Legitimate infrastructure can be abused.
- Antivirus non-detection does not prove safety.
- Employee installation does not prove legitimacy.
- Unsigned or unapproved software does not automatically prove malware.
- Confirmed security impact can justify incident classification even when malware attribution remains unresolved.
- Business impact should influence how containment is implemented, but should not override evidence.
- Containment decisions should change when the evidence changes.
- Earlier decisions should be judged using the information available when they were made.
- Management needs concise risk, action, uncertainty, and business impact.
- Engineers need detailed evidence, provenance, process, file, and network data.
- Confidence should be attached to specific findings rather than expressed as a single blanket judgment.

A detailed Lessons Learned response to all required questions is maintained separately in lessons-learned.md.

Final Disposition

Disposition

Confirmed Security Incident - unauthorized external transmission of Finance data through unapproved and unverified software, with malware status and ultimate root cause unresolved.

FIN-WS17 should remain isolated pending remediation and validation. Finance should continue operations using trusted systems, validated business data, and approved software.